

Counting Versus Testing the Destination: A Simulation Study of Layered Defences Against SMS OTP Flooding and Pumping

Naveed Ahmed^{a,*}

^a*College of Computer and Information Science, Prince Sultan University, Saudi Arabia*

Abstract

Endpoints that send one-time passwords via SMS are abused to waste money (flooding) or to earn part of the termination fee (SMS pumping). We evaluate in simulation a twelve-step defense that draws trust from app attestation, signed sessions, and verification outcomes, against simpler designs and 25 attacker profiles. Attacks with a signature in the request are contained at a low cost to simulated users; a residential attacker with farmed CAPTCHA scores is rationed by refusing half of the first-time users. On the destination, short-window counters of SMS sent per number block, selected at a benign service target, leaked 6 to 48 messages against four concentrated 20-minute pumpers at 0.06 to 0.43 points of attack-free completion, where at the busiest density, the default sequential tests of verification outcomes leaked 19 to 452. Under a second predeclared protocol on seeds and workloads held out from selection, the frozen counter met its leakage and benign-cost claims, leaked no more than the tests in all but 13 of 144 cells, all against an instantly verifying carrier, and failed both service-under-attack claims when the pumper shares blocks with real users. For attacks of up to an hour, unfitted estimates whose crossing is algebraic, not a measured switching point, ordered the policies' mean leakage in 18 of 18 decisive boundary cells with the counter's cold-start bound and 17 with its warm-start bound: the counter loses its advantage against paced or widely spread pumpers.

Keywords: SMS pumping, artificially inflated traffic, one-time password, rate limiting, sequential tests, fraud prevention

*Corresponding author.

Email address: `nahmed@psu.edu.sa` (Naveed Ahmed)

1. Introduction

Most online services verify a phone number by sending a code via SMS from an endpoint reachable before any account exists, at a tenth of a cent to twenty cents per message. A flooder makes the service send to numbers it does not own; a pumper sends to a range whose operator shares the termination fee, turning the service’s SMS budget into its income [1]. Twitter’s owner said in 2023 that pumping had cost the company approximately \$60 million a year [2], and Huh et al. found as many attack requests as genuine ones in three months of one large service’s logs [3].

We study the defenses of a registration flow: a baseline of seven controls (v1) and a twelve-step redesign with attested platforms, signed sessions, number checks before a message is paid for, reputation from whether codes were entered, a five-response risk score, and a hard budget. We ask in simulation which attacks it contains against simpler designs, at what cost in completed registrations (RQ1); which layer is responsible (RQ2); when outcome-based reputation separates an attacker from simulated users (RQ3); what rationing costs when it does not (RQ4); and what destination policies cost legitimate users, with and without an attack (RQ5).

Because a pumper is paid only on its partner’s ranges, the study focuses on the destination: under a predeclared comparison, a plain counter of sends per number block leaked less than our sequential tests of code outcomes, and a second predeclared protocol mapped where that holds and fails. We contribute an analysis of eight gaps in the baseline, the design, and an open implementation, measurements of where reputation stops separating and what rationing depends on, both destination-policy comparisons with their failures and collateral damage, and unfitted estimates of when counting leaks less than our tests; Sections 7.1–7.4 provide context.

2. Background and related work

Revenue-share fraud. In international revenue-share fraud, traffic is generated to an advertised number range, and the termination fee is split along the route [4]. Sahin and Francillon’s 3.14 million test numbers from twelve providers show that the range is the fraudster’s managed asset [5].

33 *Detecting artificially inflated SMS.* Huh et al. trained gradient-boosted trees
34 on 9.4 million SMS authentication logs from nineteen countries, reaching
35 89.6% recall at 0.19% false positives on web traffic [3]. Approximately 73% of
36 web attacks sent four or fewer requests per identity a day, defeating per-entity
37 limits, and destination signals were the strongest: about 92% zero conversion
38 for attacks against 21% for genuine traffic. Their detector requires labeled
39 traffic and acts per request. Their data show that destination aggregation
40 is informative; we add a controlled comparison of two label-free ways to act
41 on it per block, from send counts or code outcomes, and of their cost to
42 users sharing a block. Theirs was not reproduced, so the two are not ranked.
43 Zalisky and Odarchenko count A2P sends per prefix (a number less its last
44 three digits) in fixed or rolling five-minute windows and quarantine a prefix
45 for 24 hours past a day or night threshold [6]. On metadata of two confirmed
46 incidents fixed windows blocked 95% and 63% of the traffic, and 58% of a
47 legitimate marketing campaign; counting unique recipients blocked 2% of the
48 campaign and none of the first incident. Theirs is a send counter judged on
49 real traffic by messages blocked; ours compares a counter with outcome tests
50 at a service target, in simulation, by what users sharing a block lose; the
51 numbers are not comparable.

52 *Defenses in practice.* Twilio’s Fraud Guard blocks regions known for pump-
53 ing [7], and its SMS Pumping Risk Score advises friction from 60 and refusal
54 above 90 [8], so graded destination action is established; no product was
55 benchmarked. CAPTCHA solving is a labor market at approximately \$1 per
56 thousand [9], open where machine solvers fail [10]; client puzzles [11] were
57 not evaluated. Residential proxy addresses rotate within minutes [12], and
58 carrier-grade NAT makes address reputation on cellular networks “all but
59 infeasible” [13].

60 *Identity and change detection.* One entity can present many identities [14],
61 and a signed session provides continuity, not scarcity. Our block tests are
62 Wald’s sequential tests [15] run as Page’s cumulative sums [16]. Quickest
63 change detection minimizes delay under false-alarm constraints [17], and a
64 CUSUM’s parameters follow from the error rates it must meet [18]; windowed
65 statistics and confidence sequences [19] were not evaluated, so ‘testing’ be-
66 low means our conversion and speed tests only. Step 7 resembles risk-based
67 authentication [20], and attacks on the code once sent are a separate prob-
68 lem [21, 22].

69 3. Baseline and threat model

70 The baseline, v1, sends a code to any unregistered number behind seven
 71 controls: reCAPTCHA v3 on web requests only, one message per number per
 72 minute, five requests per address per minute, a country allow-list, a body-
 73 length limit, a proxy block, and per-platform caps; bulk and test paths skip
 74 some checks. Table 1 lists eight assumptions behind these rules and how an
 75 attacker within the threat model breaks each; the gaps follow from the rules,
 76 not observed abuse.

Table 1: v1 Assumptions and how they fail

Gap	v1 assumes	How it fails
A	A platform header says which app sent the request	Sending the header reaches every exemption
B	Five requests per address per minute bound an attacker	A fresh residential address per request
C	A number given is worth sending to	Generated numbers cost as much as real ones
D	An allowed country is a safe destination	Premium ranges inside it cost far more
E	Per-key caps bound total spend	A wide attack under every cap
F	Check-then-increment is a rate limit	Two racing instances both pass
G	Bulk and test flags are internal	Neither needs stronger authentication
H	Each check says which check failed	Thresholds can be probed one at a time

77 *Threat model.* The attacker wants as many messages sent as possible, or
 78 sent to numbers that pay it. It buys residential proxies and human-like
 79 reCAPTCHA tokens (about 0.3 cents each), mints fingerprints, generates
 80 numbers, and knows the thresholds. A pumper also has a colluding operator’s
 81 ranges, where it may enter codes, report deliveries as failed, build verified
 82 history, spread over blocks, and buy challenge solutions. It cannot forge an
 83 attestation, use ranges its partner does not terminate, or make a stranger
 84 enter a code.

85 4. Design

86 No message is paid for before every check passes, and cheap checks run
 87 first. Trust comes from evidence the client cannot forge, an attestation, a

88 server-signed session, and the fate of earlier codes, though such evidence can
 89 be manufactured (Section 7.8).

90 4.1. The pipeline and the risk score

91 A request passes the steps of Table 2, which lists in brackets the gaps
 92 of Table 1 each step addresses (FB: the feedback loop), until it is refused.
 93 Step 0 takes the platform only from a valid App Attest or Play Integrity
 94 result. Each limit and reservation is one atomic Redis operation, but the
 95 enclosing steps are not one transaction: on the normal path, a refused request
 96 returns its per-number claims and counter slot, and the hourly budget is
 97 reserved only for a message about to be enqueued, a reservation rather than
 98 a completed dispatch; a crash between them can leak reservations (Section 6).
 99 Address limits and source caps count requests, except that a request Step 11
 100 challenges returns its source-cap count. Every outcome after Step 0, except
 101 the challenge, returns one HTTP 200 body after at least 400 ms, a floor that
 102 cannot hide longer work.

Table 2: Twelve Steps and the v1 Gaps They Address

Step	Check
0	Proxy block; platform from attestation, never from the header [A]
1	Signed session bound to a fingerprint; 3 requests per session per 10 min [B]
2	Limits per address, /24 and ASN, lower for hosting ASNs [B, F]
3–4	reCAPTCHA v3 threshold and origin check, web only
5	Number intelligence: cost class, sequential numbers, liveness; reads the block’s verdict stage [C, D, G]
6	Body length, excluded numbers; test bypass needs a credential [G]
7	Risk score and tier: allow, delay, challenge, downgrade, block [H]
8	Per-number backoff, 60 s doubling to 1 h, five a day
9	Per-source, platform and country caps with an adaptive multiplier
10	Operating mode: elevated above 80% of the hourly budget, emergency at 100% [E]
11	Reserve hourly count, spend and any destination slot; write state; enqueue; uniform response [E, H]
FB	Outcomes per key; destination-block tests; denylist of fine keys

103 Step 7 computes

$$s = \sum_i w_i x_i + w_c \frac{\max(0, \theta - r_{\min})}{\theta} + w_s f + w_m i - w_v v_n - w_f v_f, \quad (1)$$

104 where the x_i are request signals (CAPTCHA score, hosting ASN, fingerprint
105 age, session requests, country mismatch, number class), $r_{\min}$ is the lowest con-
106 version ratio over the request’s keys (address to destination block), $\theta = 0.3$,
107 $w_c = 25$, f and i flag a flooded key and one whose codes are entered within
108 seconds, and v_n , v_f mark a number and fingerprint with verified history;
109 other weights are 5 to 25 [23]. Tiers start at 20, 40, 60, and 80: *allow*,
110 *delay* (a doubling wait), *challenge* (-20 when solved), *downgrade* (push or
111 WhatsApp), and *block*.

112 4.2. The feedback loop

113 A send resolves as *verified* when its code is entered, *fails* after five in-
114 correct attempts or two minutes past the delivery receipt, and is *undelivered*
115 without a receipt in 60 s or with a failed receipt; only the first two count
116 toward reputation. A positive receipt after a negative one reopens the send;
117 a late verification reclassifies it, but an issued verdict stands. Each transition
118 records its effects and its time in the same compare-and-set, and a recovery
119 sweep completes the work of a dead process; each effect type applies at most
120 once, and exactly once if the sweep runs within 20 minutes. Reputation
121 counts land in the transition’s hour, and a block keeps its latest outage fail-
122 ure time; however, a block’s statistic accumulates in processing order, and a
123 verdict is dated at the event that completes the crossing; thus, a late event
124 can backdate a verdict that contains later evidence, moving its expiry and
125 the next test’s start (by 10 min in one diagnostic). Simulated runs apply
126 events in time order, but concurrent live instances may not, because a tran-
127 sition is committed before its effects apply; thus, the same dependence holds
128 live unless a block’s effects are serialized.

129 4.3. Destination policies

130 A pumper is confined to its partner’s ranges but can rotate numbers
131 and blocks within them. Destination policies are keyed on the 8-digit block
132 (10 000 numbers); therefore, protection weakens as a pumper spreads.

133 *Sequential tests.* The conversion statistic assumes that users verify with $p_\ell =$
134 0.8 and a flooder with $p_a = 0.1$: a failure adds $\ln \frac{1-p_a}{1-p_\ell} = 1.50$, a verification
135 $\ln \frac{p_a}{p_\ell} = -2.08$. The speed statistic assumes that a machine enters a verified
136 code within five seconds with $q_a = 0.9$ and a person with $q_\ell = 0.2$, because
137 autofill removes the keystroke [24, 25]; it adds 1.50 or -2.08 . A verdict is
138 issued, and the statistic is reset when either exceeds $h = \ln 1000 = 6.91$.

139 The floor $S_t = \max(-ch, S_{t-1} + \text{increment})$ sets the memory: unbounded c
 140 is Wald’s test, $c = 0$ Page’s cumulative sum; the default is $c = 1$. A first
 141 verdict makes the block’s first-time clients pass a challenge for an hour; a
 142 second within the hour moves them off SMS, refusing those without another
 143 channel.

144 *Counters.* A counter limits the number of SMS sent per block in a daily or
 145 short refilling window. Step 11 reserves a slot and decides the stage in one
 146 atomic operation when an SMS is about to be sent, so concurrent requests
 147 cannot skip the challenge. Past the limit, a graded counter challenges first-
 148 time clients, and past twice the limit moves them off SMS; a refusing counter
 149 refuses. Clients with verified history are exempt from both policies; therefore,
 150 a code entered on a pumper’s number can buy that number an exemption. A
 151 token bucket of the same rate (burst 4 or 12; its challenge-tier bucket refills
 152 independently, unlike RFC 2697’s [26]) and the counter combined with the
 153 tests were also explored.

154 4.4. Capacity controls

155 Step 9 multiplies its caps by 0.25 to 1.5 according to a baseline job com-
 156 paring each key with its expected rate, learned from the pipeline’s hourly
 157 counters; without history, the static cap stands. Verified history avoids adap-
 158 tive reduction, not the static caps or the budget, which bounds SMS count
 159 and spend, not vendor or fallback costs.

160 5. Leakage estimates and a heuristic crossover

161 We compare the SMS sent to a pumper’s number over an attack of $T \leq 60$
 162 minutes, by a pumper that solves no challenge and holds no verified history.
 163 Against the sequential tests, one reaching B blocks with N requests at rate
 164 λ leaks about

$$L \approx \min(N, kB + \lambda\tau), \quad k = \lceil h/1.50 \rceil = 5, \quad (2)$$

165 before its first verdict, where τ , the time a send stays unresolved, is the
 166 resolution timeout plus the delivery delay plus half the timeout worker’s
 167 period (2.55 minutes) if the carrier never verifies, and seconds if it verifies
 168 at once. Judged, such a pumper is held for the verdict’s hour; therefore,
 169 for $T \leq 60$ Equation (2) also estimates the attack’s total, ignoring prior
 170 credit and outage suspension. A carrier verifying a share σ of codes with

171 a human-like delay gives the conversion statistic an expected increment of
 172 $\sigma(-2.08) + (1 - \sigma)(1.50)$, zero at $\sigma^* = 0.42$; above it, the statistic drifts away
 173 from a verdict.

174 A counter of q sends per block opens a window with the block's first
 175 reserved SMS and closes it after the window length. A pumper that finds its
 176 blocks' counters empty (a cold start) sends at most

$$L_c \leq \min(N, qBw), \quad w = \lceil T/\text{window} \rceil, \quad (3)$$

177 whatever its carrier does with the codes. If a legitimate send has already
 178 opened a window on block b , using $c_b \geq 1$ slots, the pumper can also take
 179 the remaining $(q - c_b)^+$ before at most w further windows open, so in general

$$L_c \leq \min\left(N, qBw + \sum_{b \text{ open}} (q - c_b)^+\right) \leq \min(N, B(qw + q - 1)). \quad (4)$$

180 Solving challenges doubles these bounds, and a verified history exempts a
 181 client from them. While neither policy's estimate reaches N , the cold-start
 182 bound lies below the tests' estimate when

$$B(qw - k) < \lambda\tau, \quad (5)$$

183 and a warm start adds the residual quota to the left side. Equation (5)
 184 is the algebraic crossing of two simplified quantities, neither of which is an
 185 empirically established switching point or a necessary condition: other limits
 186 can hold either policy below its estimate. A carrier that games outcomes
 187 may never be judged, so the tests' leakage approaches N .

188 In the code, every send takes a slot, verified clients' included. If a block's
 189 sends arrive as a Poisson stream with mean m per window and all reach the
 190 counter, a window holds $1 + X$ of them, $X \sim \text{Poisson}(m)$, and the idealized
 191 share beyond the quota is $E[(1 + X - q)^+]/(1 + m)$: 7.3% at $m = q/2$ and 27%
 192 at $m = q$ for $q = 4$. This is not a challenge rate: exempt clients take slots
 193 without challenge, and challenge failures, the second tier and earlier gates
 194 are ignored. The estimates use only the rules, configuration, and attack rate;
 195 what an excess send costs a user needs the simulation.

196 6. Implementation and evaluation method

197 *Implementation.* Approximately 4000 lines of Python implement the
 198 pipeline on in-memory and Redis backends. Up to release 2.8.3, the sim-
 199 ulator's in-memory store let a sorted set expire a fixed time after its first

200 write, whereas Redis kept it while written to; therefore, the simulated outage
 201 detector and Step 5 lost recent observations. Release 2.9.0 follows Redis in
 202 every rule compared, checked by differential tests, and every study was rerun
 203 with it; earlier releases repaired seven replay and concurrency defects, each
 204 with a regression test. Of 453 tests, 19 used a real `redis-server`, 18 tested
 205 specific interleavings of two instances, not all. Step 11 was still not one
 206 transaction: a crash after its reservations leaked reserved slots or resolved
 207 the send as undelivered. The implementation was a research prototype.

208 *Simulation.* The pipeline runs against scripted vendor fakes on a simulated
 209 clock. After a warm-up of ten minutes (30 or 130 for pumping), attacks run
 210 over legitimate traffic at 20 requests per minute. Simulated users verify 80%
 211 of codes after a lognormal delay (median 22s; 2s for the 20% using autofill);
 212 70% of numbers are reachable on WhatsApp; 90% of users complete a chal-
 213 lenge; 20% are returning account holders with a stable fingerprint, a trusted
 214 number, and verified history; thus, the results for returning users describe
 215 trusted identities only. Separate random streams provide all scenarios at the
 216 same seed with the same users.

217 Three behavioral parameters have published counterparts: genuine con-
 218 version (one provider’s 68% or more [27]; ours 60%–90%) and the never-
 219 converting destinations and identity churn of Section 2; the rest are assump-
 220 tions. Table 3 groups the attacker profiles by capability and marks the des-
 221 tination policies each faced (S, sequential tests; C, counters; B, block-limit;
 222 parameters in `results/attacker_profiles.md`). Attackers draw pool size,
 223 rate, and CAPTCHA class per seed, which explains 92% [80, 98] of the vari-
 224 ance of the farm’s leakage in a nested design (ten configurations, three seeds
 225 each). Brackets in the text and tables, and bars and bands in the figures,
 226 are 95% percentile-bootstrap intervals over seeds, paired per seed for differ-
 227 ences; they describe variation under this generator, not uncertainty about
 228 real traffic.

229 *Two protocols and their chronology.* A supplementary map (`results/`
 230 `study_map.md`) gives each study’s seeds. The first protocol, committed
 231 before its runs, fixed the matched comparison and a robustness study over
 232 12 Latin-hypercube points (conversion 0.6–0.9 and five other behavioral pa-
 233 rameters) and a held-out family (60 to 120 attack requests a minute, 50 000
 234 to 500 000 addresses, heterogeneous legitimate traffic), with claims C1–C5
 235 that hold if true in 90% of cells, a benchmark convention, not a confidence

level. The matched comparison changes only the destination policy and, at three block densities, selects on tuning seeds the least leakage summed over four concentrated pumpers among settings at or above the *tuning target*, the default’s completion minus 0.5 points. The robustness study’s first run failed C1 in 32 of 108 cells because attack and no-attack runs drew different users; we fixed the pairing, a fix that followed a result, and reran every study. The second protocol (claims K1–K5) was written after the matched comparison had selected three counters and committed before its runs; six of its seed values had served other robustness points, never selection. Both were rerun unchanged with 2.9.0 (9 919, 7 925 and 240 runs, each carrying its code hash); against 2.8.0, total leakage changed in 855 of 17 964 comparable runs, but the principal selections, eligibility decisions, and claim counts did not; one auxiliary setting (false alarms matched at unbounded credit) moved from *T1000* to *T300* under both protocols (artifact change report).

Designs and metrics. Seven designs: **v1**, **v1-corrected** (attested platform), **budget-only** (sessions, static caps, budget), **block-limit** (a refusing counter of five sends per block per day), **conversion-only** and **speed-only** (v2 minus one block test), and **v2**. A seed is *contained* when leakage stays at most 5% of the attack rate from some minute to the window’s end, for five minutes or more. *Attributable* loss compares the same requests with the policy enforced and absent, net of the reverse, in points of offered users: on attack-free traffic it is the *benign cost*, on the attacked trace the *extra harm* relative to the attacked no-policy arm. *Degradation* compares the attacked trace with attack-free operation under the same policy.

7. Results

7.1. RQ1: what is contained, and at what cost

Table 4 gives the leaked share (% , mean of per-run shares) of about 600 attack requests in 20 minutes over 30 seeds under v1, block-limit (BL) and v2 with source caps lifted, and under v2 with caps on, with the first-time users refused and all users completing (%); supplementary Table S1 (**results/design_table.md**) gives every design with intervals. Datacenter rotation leaks nothing under v2 because it scores in the challenge tier and declines challenges; Step 5 refuses the premium range, and the session cap holds the single client to two messages (Table 4); in all 108 robustness cells, these

Table 3: Attacker Profiles, Capabilities, and Policies

Capability	Profiles	Policies
A signature in the request (5)	One address; datacenter rotation abroad; a premium-rate prefix; numbers walked upward; the farm with an unattested iOS header	S, B
Looks like a person (7)	Residential bot; farmed CAPTCHA with fresh or aged fingerprints; one 48-hour-old browser profile	S, B
	Low and slow, 2 or 10 requests/min over 20 ASNs; datacenter rotation buying challenge solutions	S
Games outcomes or trust (8)	Pumpers on elevated-cost or standard ranges verifying within 1 s, or 60% after 30 s	S
	Threshold-aware and receipt-faking carriers; three trust builders (500 identity/number pairs verify for 10 or 30 min, then flood)	S, C
Concentrated on the destination (5)	Four pumpers on three blocks (carrier never verifies, verifies within 1 s or 60% after 30 s, or buys challenges); a poisoner on users' blocks	S, C
Spread (generated)	3 to 300 blocks, at full rate or at most the counter's quota per block	S, C

Table 4: Leakage and User Impact Across Designs

Attacker	caps lifted: leaked			caps on, v2		
	v1	BL	v2	leaked	refused	completed
Single client	5.6	0.3	0.3	0.3	1.1	79.1
Datacenter rotation	69.0	69.0	0.0	0.0	1.1	79.1
Premium pumping	99.4	1.0	0.0	0.0	1.1	79.1
Sequential numbers	99.4	1.0	11.5	10.7	3.5	77.5
Reused profile	99.5	99.5	22.5	17.4	8.6	74.2
Residential bot	37.2	37.2	37.2	29.9	16.2	69.6
Farmed CAPTCHA	99.5	99.5	99.5	45.6	54.0	45.5
Aged fingerprints	99.5	99.5	99.5	45.6	54.0	45.5
Forged header	100.0	99.5	99.5	45.6	54.0	45.5

attacks leaked under 5% at completion within two points of the paired no-attack run (claim C1). The walk leaks 61 [53, 70] messages before its block's verdict (block-limit: five), and the reused profile 89 [83, 95].

The farm leaks 99.5% with caps lifted under every design; v2's adaptive cap holds it to 229 [215, 244] messages, 46%, by refusing 54% [47, 60] of first-time users, so 45.5% complete instead of 76.4% under v1: rationing (claim C5 held in 36 of 36 cells).

7.2. RQ2: conditional effects of each layer

In the ablation grid (90 effects, each conditional on all other layers, unadjusted intervals; artifact), removing the adaptive caps lets the farm leak

310 [194, 421] more messages; the risk engine, feedback loop, and block key
 311 hold the walk by 166, 152, and 121 messages, and the loop holds the reused
 312 profile by 138. The key acts only through the loop (interaction -121 [-141 ,
 313 -101]).

314 7.3. RQ3: where reputation stops separating

315 A farmed-CAPTCHA attacker uses an address and fingerprint once and
 316 shares its country, prefix, and residential ASN with every legitimate user;
 317 thus, its failures penalize everyone: over an hour with caps lifted (five seeds),
 318 up to twice the legitimate rate, 99 to 100% of it leaks, since a shared key stays
 319 above 0.3 conversion until failures outnumber legitimate sends about 1.7 to
 320 one. At ten times, 70% leaks while 17% of legitimate users are challenged
 321 and 3.2% refused (claim C2, at least 90% leaked with caps lifted, held in 34 of
 322 36 cells). No single score change separates better: a fresh-fingerprint weight
 323 of 40 stops it only by challenging 47% of legitimate users. In the settings
 324 run, reputation separated an attacker only on keys its sends dominated [14].

325 7.4. RQ4: what rationing costs, and what it depends on

326 When separation fails, the cap is the lever: over ten seeds, the default lets
 327 47% of the farm’s requests through and refuses 41% of all legitimate users,
 328 the tightest setting 20% and 64%. Both assume an oracle job that is told the
 329 legitimate rate and runs every minute; running every five minutes or hourly,
 330 it lets 75%–96% through. Learning the rate from the pipeline’s counters, the
 331 deployed job leaks 193 [161, 229] messages with a clean three-week profile,
 332 340 [239, 441] more on a cold start, 106 [62, 151] more with a stale profile,
 333 and 45 [10, 77] more with a poisoned one.

334 7.5. Pumping against the sequential tests

Table 5: Containment Results for Concentrated Pumping Attacks

Carrier, design	Leaked (msgs)	Contained (seeds)	Containment (min)	First verdict (min)	Codes entered
never verifies: v1	570 [419, 736]	0/10	–	–	0
v2 default	90 [71, 114]	10/10	3.5 [3.1, 3.9]	3.0	0
verifies within 1 s: v2 default	19 [17, 21]	10/10	1.4 [1.1, 1.7]	0.4	19
verifies 60% after 30 s: v2 default	452 [365, 539]	0/10	–	11.6	272
v2 default, 60 min	1 067 [839, 1 310]	2/10	47.0 [42.0, 52.0]	25.5	–
buys challenges: v2 default	106 [87, 127]	10/10	4.3 [3.8, 4.9]	3.0	0

Table 5 covers concentrated pumpers on three blocks with caps lifted over ten seeds: messages leaked of about 574 requests in 20 minutes, seeds contained, mean minutes to containment (contained seeds) and to the first verdict (seeds with one), and codes entered. The speed test catches a carrier verifying within a second at 19 messages, while the carrier verifying 60% with human-like delay is contained in none of the ten 20-minute runs: its first verdict comes at minute 11.6 on average and 452 messages leak; in an hour, 1 067 leak and two of ten runs are contained, at minute 47.0 on average. Claim C3 (containment with at most 30% leaked) held in 36 of 36 cells.

Across 18 spread configurations, leakage follows the blocks touched: with 30 blocks, five to seven runs in ten are still contained. Unsaturated, Equation (2) errs by 1.6 to 7.9 messages per run (1%–13%, ten configurations); saturated, it overstates by up to 91.

7.6. Destination policies: where the counter wins, and where it fails

Table 6: Leakage and Benign-User Impact Across Carrier Types

Setting (selected as)	NV	IV	HL	CB	Compl.	Benign	Chall.	Events
none	319	566	570	405	64.13%	–	1.53%	0
sequential <i>T</i> 1000, <i>c</i> 1 (default)	90	19	452	106	64.12%	0.01	1.64%	6.5
sequential <i>T</i> 300, <i>c</i> 0 (selected at tuning target)	88	14	126	98	63.77%	0.37	6.54%	334.3
counter, graded, 4 per 10 min (selected)	24	24	24	48	64.07%	0.06	2.38%	0
counter, graded, 160 per day (selected daily)	319	409	408	405	64.11%	0.02	1.87%	0

At a benign service target. Table 6 reports the first protocol at 200 blocks (144 legitimate sends per block a day; tuning seeds 100–102, evaluation seeds 0–9): 20-minute leakage against the never-verifying (NV), instant (IV), human-like (HL) and challenge-buying (CB) carriers and, from 24-hour attack-free runs at 65% conversion, completion, benign cost (points), users challenged and verdict events a day; the tuning target is 63.95%. Figure 1 plots each setting’s completion against its leakage summed over the four pumpers’ runs of a seed (not one combined attack), with the tuning target dotted; its unlabeled points are sequential settings matched to the default’s false alarms at other credits (key: `results/figure1_key.md`). Figure 2 gives each selected setting’s leakage minus the default’s, paired per seed (negative: leaks less). The sequential setting selected at the tuning target holds the human-like carrier to 126 messages only by raising 334 false verdict events a day, and misses the target by 0.18 points on seeds 0–9. The

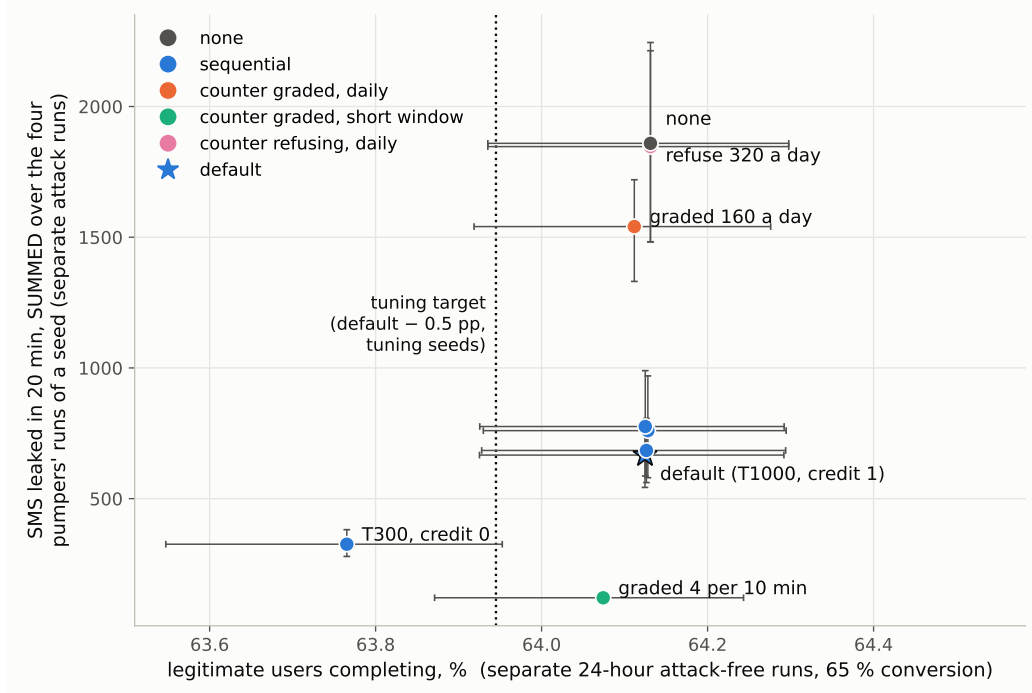


Figure 1: Leakage vs. Legitimate-User Completion Across Settings

333 graded counter of four sends per block per ten minutes leaks 24 against
 334 each outcome-reading carrier and 48 against the challenge buyer, at 0.06
 335 points; counters selected at the sparser settings leak 6 to 18 at 0.15 to 0.35
 336 points (up to 0.43 at 80%). With the full grid and density-specific attacks
 337 (E5) the rule selects the same counters, and so do other objectives on the
 338 tuning runs (worst-case leakage, a first-time-loss constraint, each attacker
 339 alone, 2000 random mixes), except the instant verifier alone and 3 mixes at
 340 200 blocks; on fresh seeds the counter leaked least of the winners against
 341 every attacker but the instant verifier (25, against 15 and 16). On seeds
 342 300–309 the 1000-block counter falls 0.12 points below its target, yet no
 343 seed-and-conversion cell fails the paired check (the evaluation default minus
 344 0.5 points).

345 *Under a second protocol.* Table 7 covers 12 shifted points of the held-out
 346 family, with held-out attack rates and pools, three seeds each and a 20-
 347 minute pumper on three blocks real users share; a claim holds if true in 90%
 348 of cells, which share workloads and seeds and are not independent, and IV

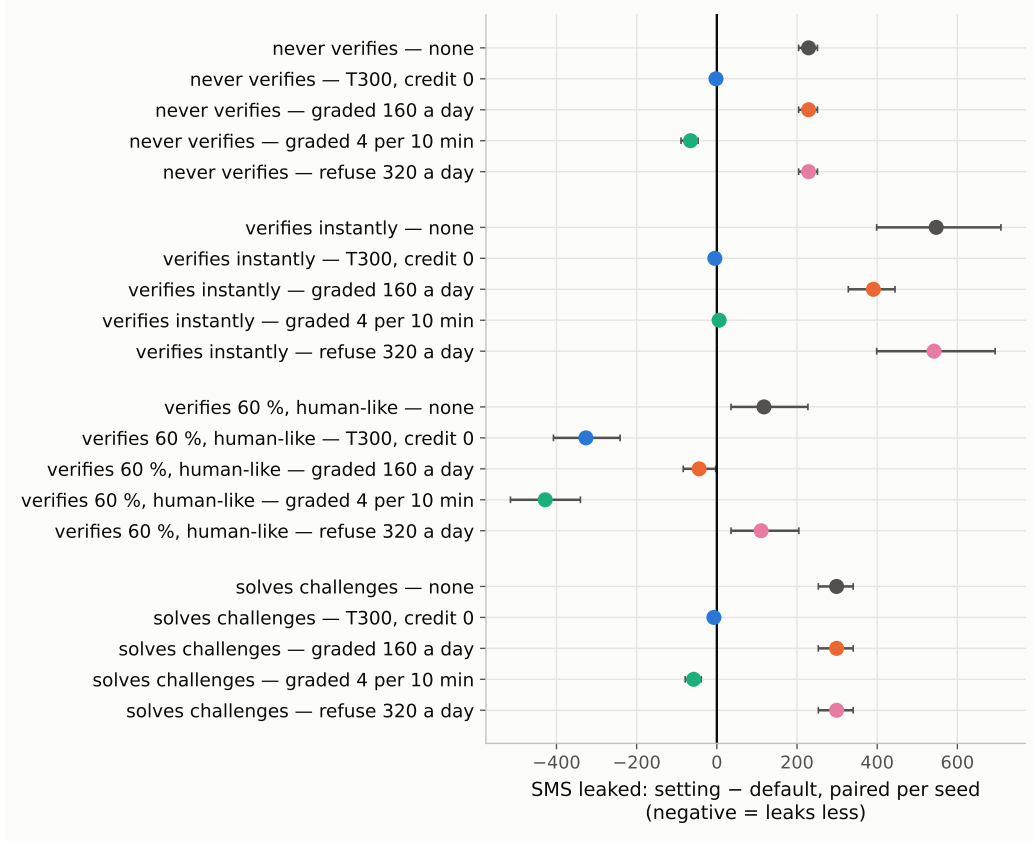


Figure 2: Leakage Difference from the Default Across Attack Types

Table 7: Held-Out Evaluation of the Principal Counter

Claim	Statement	True / cells	IV	Result
K1	Leaks at most 10% of attack requests	144/144 (100%)	36/36	holds
K2	Attack-free attributable loss at most 0.5 points	36/36 (100%)	–	holds
K3	Attributable loss under attack at most 0.5 points	127/144 (88%)	32/36	fails
K4	Leaks no more than the default sequential tests	131/144 (91%)	23/36	holds pooled, not for IV
K5	Attributable loss under attack at most the default’s plus 0.25 points	93/144 (65%)	23/36	fails

marks the instant verifier’s cells. Frozen and run on this family, the counter leaked 33, 34, 33, and 62 messages against the four carriers, where the default leaked 287, 36, 344, and 287, and no policy 451 to 1857, at a benign cost

Table 8: Leakage and User Harm Under Shared-Block Pumping

Policy	Leaked (SMS)	Extra harm against attacked, no policy		Degradation against attack-free, same policy		Benign cost
		all users ($\approx 1\,200$)	attacked blocks (≈ 18)	all users	attacked blocks	all users
none	5 509 [4 409, 6 567]	—	—	0.19	8.0 [5.1, 10.7]	—
sequential, default	1 149 [953, 1 340]	−0.07	−1.0 [−2.8, 0.8]	0.10	7.0 [4.7, 9.1]	0.02
sequential <i>T</i> 300, <i>c</i> 0	397 [312, 481]	0.13	0.9 [−1.3, 3.3]	0.12	8.9 [6.0, 11.7]	0.20
counter, 4 per 10 min	403 [386, 418]	−0.05	−3.2 [−5.0, −1.1]	0.07	4.8 [2.9, 6.7]	0.07
counter + sequential	190 [179, 201]	−0.04	−3.1 [−5.1, −0.7]	0.07	4.9 [3.0, 6.8]	0.08
token bucket, burst 4	424 [412, 437]	−0.12	−3.1 [−5.1, −0.7]	0.07	4.9 [2.8, 7.0]	0.00
token bucket, burst 12	545 [531, 559]	−0.11	−2.1 [−4.3, 0.2]	0.08	5.9 [3.3, 8.8]	0.00

Table 9: User Harm Under a Full-Block Poisoning Attack

Policy	Leaked (SMS)	Extra harm against attacked, no policy	
		all users	first-time users
none	1 976	—	—
sequential, default	1 357	1.09 [0.59, 1.59]	1.36
sequential <i>T</i> 300, <i>c</i> 0	858	2.55 [2.04, 3.07]	3.20
counter, 4 per 10 min	1 662	0.72 [0.44, 1.02]	0.91
counter + sequential	1 286	1.43 [0.88, 1.97]	1.79
token bucket, burst 4	1 877	0.12 [0.04, 0.23]	0.16
token bucket, burst 12	1 974	0.00 [0.00, 0.00]	0.00

of 0.13 [0.09, 0.17] points, and failed both service-under-attack claims: 13 of the 17 cells that broke K3 lie at the three points with the most legitimate traffic, where users and pumper compete for one quota; K5 failed in 51 cells over 11 of 12 points. The counters selected for sparser traffic cost 4.7 and 5.8 points here even without an attack: the quota must match the traffic.

Tables 8 and 9 report E1 at 200 blocks (60-minute attacks, seeds 300–309): a pumper on three blocks real users share, and a poisoner flooding all 200 blocks. Leakage under the pumper is summed over the four carriers’ runs of

360 a seed, which can hide a carrier on which a policy loses (per carrier: artifact);
 361 harm is net completions lost in points, averaged over the carriers (negative:
 362 a gain), with intervals for leakage and the attacked blocks in Table 8 and
 363 for all users' extra harm in Table 9. In Table 8, against the attacked no-
 364 policy arm, the counter cost all users nothing on average and gained the
 365 attacked blocks' users three points on average, since without a destination
 366 policy, the pumper exhausts their blocks and the hourly budget; with the
 367 human-like carrier alone, it cost them 1.9. Against the attack-free operation,
 368 every evaluated policy left those users 5 to 9 points worse off on average
 369 (2 to 12 per carrier; 8 with none): none shields a block an attacker shares.
 370 Counter and tests together, explored outside the frozen claims, leaked least
 371 summed over the four carriers but not against the instant verifier (28; $T300$,
 372 $c0$: 22), and under the poisoner (Table 9) cost all users most of the counters
 373 and buckets and leaked more than $T300$, $c0$. A token bucket with a burst of
 374 4 spared the poisoner's users only by letting almost everything through; with
 375 two untuned settings, neither limiter dominated, and we ranked only the
 376 implemented policies. Returning users, all simulated with verified history,
 377 lost nothing.

378 Figure 3 shows the counter's operating boundary (E4, seeds 300–304): in
 379 (a), the attributable loss of the three hot blocks' users against their legitimate
 380 rate, attack-free and with a never-verifying pumper on those blocks; in (b, c),
 381 leakage in 20 and 60 minutes against the blocks a pumper uses, at full rate
 382 or paced, with Equations (2)–(4) for the full-rate pumper as hollow markers.
 383 All horizontal axes and the vertical axes of (b, c) are logarithmic, and lines
 384 join sampled settings without locating a crossover. Attack-free, the counter
 385 costs a block's users nothing at one send per ten minutes, 2.3 points at four
 386 and 5.5 at eight, far below the idealized share beyond the quota (27% at
 387 four), since most challenged users complete or switch to WhatsApp; without
 388 WhatsApp, eight sends cost 13.2. A 30-minute launch at three times the
 389 normal rate costs its blocks' users 16 points. Over 60 minutes (Figure 3c)
 390 the default leaked 110, 144 and 242 messages on 3, 10 and 30 blocks, against
 391 105, 139 and 240 from Equation (2) ($\lambda\tau \approx 90$), and the counter 71, 240 and
 392 679 against its cold-start bound of 72, 240 and 720. Once 7 messages sent,
 393 exempt, to real users' trusted numbers are set aside, no counter run that
 394 started cold (44 of 100) exceeded Equation (3); three warm ones did, by 5
 395 or 6 messages, and none exceeded Equation (4). With these unfitted inputs
 396 Equation (5) ordered the policies' mean leakage in 18 of 18 decisive cells (two
 397 ties at N), and with the warm-start term in 17, missing where the estimates

398 differ by 0.8 messages (30 blocks, 20 minutes; measured difference 6.6 [−27.2,
399 42.4]); per seed, 76 of 78 decisive comparisons agree. The algebraic crossing
400 lies near five blocks for an hour and 30 for twenty minutes, where the nearest
401 measured differences (three and 30 blocks) do not exclude zero; it is not a
402 measured switching point. Paced to the quota, a pumper leaks about as
403 much under the counter as with no policy (71 against 72 on three blocks in
404 an hour), and 23 under the tests.

405 Against adaptive attackers (E3), the counter held the threshold-aware
406 carrier, receipt faker, and concentrated trust builder to 24 to 36 messages
407 (502 to 665 under the default), but not trust builders on random numbers
408 (577, as under the default); over 360 minutes, the human-like carrier gained
409 81 messages an hour under the counter, and 753 under the default.

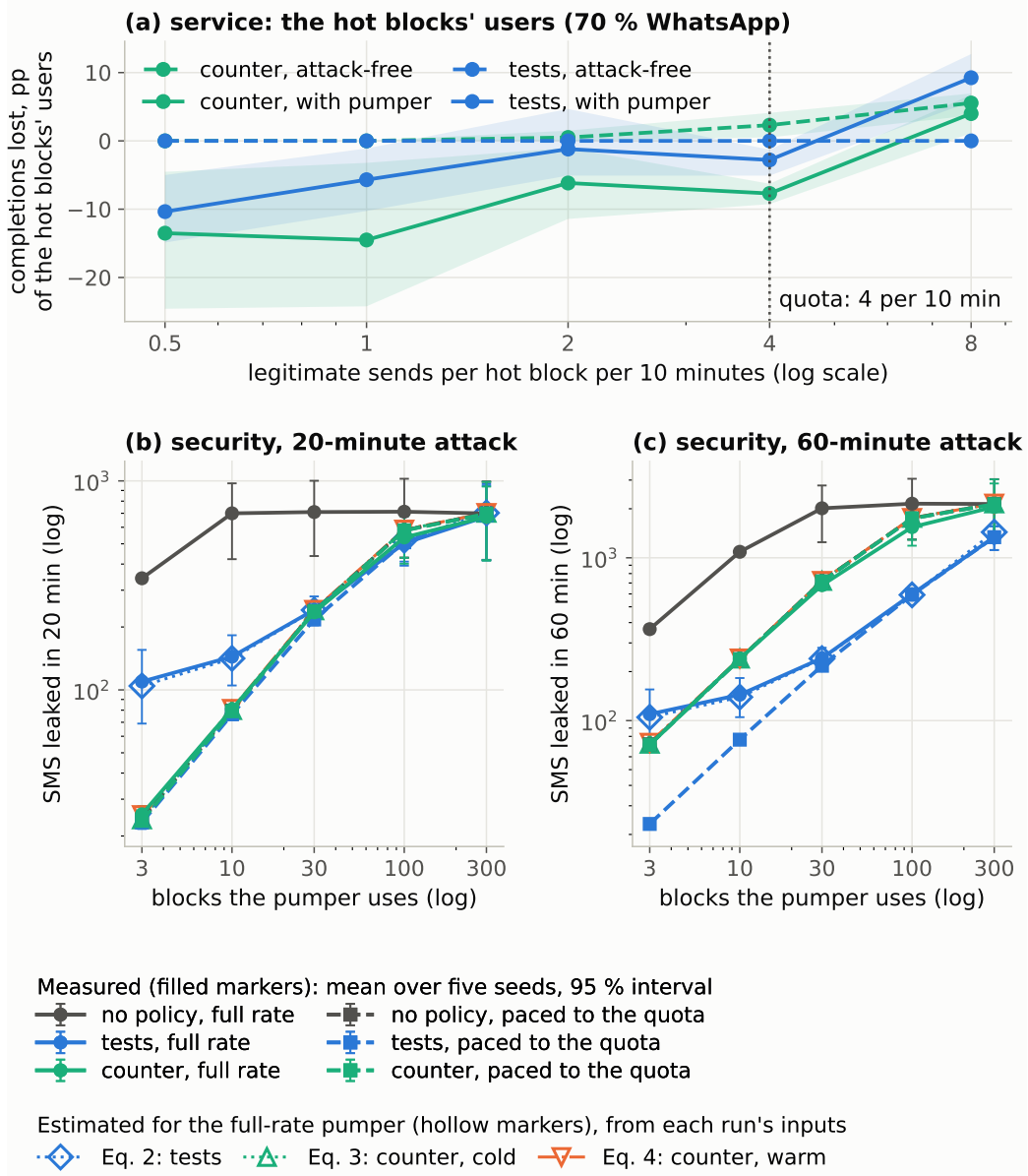


Figure 3: Operating Boundary of the Counter.

410 *7.7. RQ5: what destination policies cost legitimate users*

411 On one block, 20 000 Monte Carlo trials per cell give the probability of a
412 verdict within 30 legitimate sends: 0.09% [0.06, 0.14] at 80% conversion with
413 20% autofill, 1.9% at 65% and 19.5% at 50%. Over 24 hours, the default
414 raises 0.5 verdict events a day on 200 busy blocks at 80% conversion and 6.5
415 at 65%, where they meet 30 of about 28 800 requests (claim C4 held in 18 of
416 18 cells).

417 A poisoner flooding for 20 min the 20 blocks legitimate users concentrate
418 on (caps lifted, ten seeds) raises 16 verdict events meeting 98 legitimate
419 requests, 33 never completing; against observe-only operation on the same
420 trace, enforcement costs 12.7 [4.6, 22.9] completions, 3.1% of users (6.3%
421 without WhatsApp; 23.9% with a 24-hour denylist). One that stops after
422 ten minutes leaves verdicts meeting 406.5 requests afterwards, an attributable
423 loss of 46.2 [16.9, 79.8]. Grading limits the harm; it caps it neither at the
424 challenge nor at the attack’s duration.

425 *7.8. Adaptive attackers, economics and overhead*

426 The leakages of these scripted adaptations are not bounds. Against v2
427 with caps lifted, a datacenter attacker buying every challenge solution leaks
428 55, and a threshold-aware carrier and a receipt faker leak 570 each, drawing
429 no verdict.

430 If pumpers earn a share of the 0.1422 USD retail price and pay an event-
431 level bill, they break even at a share of 0.043 under v1 and 0.054 to 0.271
432 under v2 (the instant verifier 1.310); over 360 minutes under the counter,
433 the human-like carrier needs 1.048. These are break-even shares for scripted
434 attackers under assumed prices, not bounds or criminal profit.

435 On a real Redis (four vCPUs, four workers), sends cost 13.8 ms (me-
436 dian) and 21.1 ms (99th percentile), and 133 requests per second passed at
437 concurrency 128 with the 400 ms floor and 50 ms vendor calls. With fast
438 vendors, response times distinguished no pair of five outcome classes (small-
439 est Kolmogorov–Smirnov $p = 0.051$). Under an adversarial mixture, 81% of
440 sends overran the floor, and response-time thresholds separated sends from
441 refusals with 88% balanced accuracy on the fitted run and, fitted on a new
442 run, 95 to 99.9% on two others: a separation on that machine, not a deploy-
443 ment accuracy.

444 8. Discussion

445 *Lessons.* In the scripted workloads, carriers that verify with human-like de-
446 lay, fake receipts, or know the thresholds defeated our outcome tests but not
447 a short-window counter. Within an hour of a verdict, the counter’s allowance,
448 unlike the tests’, grows with the windows an attack spans; over longer cam-
449 paigns, verdicts expire and the tests leak again. Equation (5) summarizes
450 this for pumpers that solve no challenge and hold no exemption. Its inputs
451 are in an operator’s logs; the cost of an excess send, competition under at-
452 tack, and exemption abuse come only from the simulation. The counter and
453 tests together, with a quota set from each block’s traffic, is a hypothesis for
454 real traffic, not a recommendation.

455 *Limitations.* Everything was simulated, and calibration was assumed. Both
456 protocols were written by the author for the author’s generator, the second
457 knowing which counters had won. Some results follow from the generator (a
458 perfect premium list, a datacenter attacker that declines challenges, returning
459 users who always present verified history), and selection used an unweighted
460 sum of four scripted pumpers’ leakage and a mean service target met on tun-
461 ing seeds, which guarantees no service level elsewhere. Close rankings rest
462 on ten or fewer seeds, and costs that round to zero are not shown equivalent.
463 Per-client quotas within a block, carrier spend ceilings, bounded exemptions,
464 tuned token buckets, and other sequential statistics lie outside the evalu-
465 ated policies. Vendor adapters are untested live, and the timing result holds
466 only for the observer tested. Destination policies challenge people for what
467 strangers sharing their block did, and deployment under the GDPR or Saudi
468 Arabia’s PDPL needs a lawful basis and a route for refused users. Replaying
469 real traffic is the experiment this paper most needs.

470 9. Conclusion

471 In this simulation, the design contains attacks that carry a signature at
472 a low cost to simulated users and rations, rather than separates, residential
473 attackers that resemble people. Counting sends on the destination leaked less
474 in aggregate than our outcome tests against concentrated pumpers, although
475 not reliably against an instantly verifying carrier; a frozen counter failed
476 its service claims when the attacker shared blocks with real users and lost
477 its advantage against wide, paced, and trust-building pumpers. Within an
478 hour, unfitted estimates ordered the policies’ mean leakage in 18 of 18 decisive

479 boundary cells with the cold-start bound and 17 with the warm-start bound,
480 missing a near tie; the crossing was algebraic, not a measured switching point.

481 **CRediT authorship contribution statement**

482 **Naveed Ahmed:** Conceptualization, Methodology, Software, Valida-
483 tion, Investigation, Writing – original draft, Writing – review & editing.

484 **Declaration of competing interest**

485 The author declares no known competing financial interests or personal
486 relationships that could have appeared to influence this work.

487 **Declaration of generative AI and AI-assisted technologies in the** 488 **writing process**

489 The author used Claude (Anthropic) for code, evaluation, drafting and
490 editing; checked numbers against the recorded results and claims against the
491 code; and takes full responsibility for the content.

492 **Data availability**

493 No human or real traffic data was used. Code, protocols (`config/`), every
494 run’s configuration and outcome and the sources of headline numbers
495 (`results/`) are at <https://github.com/nahmedpsu/OTP-DDOS>, release
496 2.9.1 (tag v2.9.1), which runs unchanged the code of release 2.9.0 (tag
497 v2.9.0, commit 9af3100) that produced the results (`code_identity.md`);
498 the 2.8.0 results are in `results/historical_2.8`. These files are the
499 supplementary material.

500 **References**

- 501 [1] MITRE Corporation, Resource hijacking: SMS pumping, technique
502 T1496.003, MITRE ATT&CK, [https://attack.mitre.org/techn](https://attack.mitre.org/techniques/T1496/003/)
503 [iques/T1496/003/](https://attack.mitre.org/techniques/T1496/003/), accessed 2026-10-01.

- 504 [2] Commsrisk, Elon Musk says Twitter lost \$60mn a year because 390
505 telcos used bot accounts to pump A2P SMS, [https://commsrisk.co](https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/)
506 [m/elon-musk-says-twitter-lost-60mn-a-year-because-390-tel](https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/)
507 [cos-used-bot-accounts-to-pump-a2p-sms/](https://commsrisk.com/elon-musk-says-twitter-lost-60mn-a-year-because-390-telcos-used-bot-accounts-to-pump-a2p-sms/), trade press; the figure
508 is the company’s own claim (2023).
- 509 [3] J. H. Huh, H. Shin, S. Ahn, H. Yi, J. Cho, T. Kim, M. Lim, N. Choi,
510 Preventing artificially inflated SMS attacks through large-scale traffic in-
511 spection, in: 34th USENIX Security Symposium, USENIX Association,
512 Seattle, WA, 2025.
- 513 [4] M. Sahin, A. Francillon, P. Gupta, M. Ahamad, SoK: Fraud in telephony
514 networks, in: 2017 IEEE European Symposium on Security and Privacy
515 (EuroS&P), IEEE, 2017. doi:10.1109/EuroSP.2017.40.
- 516 [5] M. Sahin, A. Francillon, Understanding and detecting international rev-
517 enue share fraud, in: Network and Distributed System Security Sympo-
518 sium (NDSS), Internet Society, 2021. doi:10.14722/ndss.2021.24051.
- 519 [6] M. Zaliskyi, M. Odarchenko, Artificially inflated traffic in A2P mes-
520 saging: Window-based detection models and prefix-level analysis for
521 fraud mitigation, Science-Based Technologies 69 (1) (2026) 89–98. doi:
522 10.18372/2310-5461.69.20735.
- 523 [7] Twilio Inc., Verify fraud guard, [https://www.twilio.com/docs/veri](https://www.twilio.com/docs/verify/preventing-toll-fraud/sms-fraud-guard)
524 [fy/preventing-toll-fraud/sms-fraud-guard](https://www.twilio.com/docs/verify/preventing-toll-fraud/sms-fraud-guard), accessed 2026-10-01.
- 525 [8] Twilio Inc., SMS pumping risk score (Lookup v2), [https://www.twilio](https://www.twilio.com/docs/lookup/v2-api/sms-pumping-risk)
526 [.com/docs/lookup/v2-api/sms-pumping-risk](https://www.twilio.com/docs/lookup/v2-api/sms-pumping-risk), accessed 2026-10-01.
- 527 [9] M. Motoyama, K. Levchenko, C. Kanich, D. McCoy, G. M. Voelker,
528 S. Savage, Re: CAPTCHAs – understanding CAPTCHA-solving ser-
529 vices in an economic context, in: 19th USENIX Security Symposium,
530 USENIX Association, 2010.
- 531 [10] A. Dionysiou, E. Athanasopoulos, SoK: Machine vs. machine – A sys-
532 tematic classification of automated machine learning-based CAPTCHA
533 solvers, Computers & Security 97 (2020) 101947. doi:10.1016/j.cose
534 .2020.101947.

- 535 [11] D. Dean, A. Stubblefield, Using client puzzles to protect TLS, in: 10th
536 USENIX Security Symposium, USENIX Association, 2001.
- 537 [12] X. Mi, X. Feng, X. Liao, B. Liu, X. Wang, F. Qian, Z. Li, S. Alrizah,
538 L. Chen, Y. Qian, Resident evil: Understanding residential IP proxy
539 as a dark service, in: 2019 IEEE Symposium on Security and Privacy
540 (S&P), IEEE, 2019. doi:10.1109/SP.2019.00011.
- 541 [13] P. Richter, F. Wolsing, A. Chandrasekaran, R. Padmanabhan, M. All-
542 man, R. Bush, A. Feldmann, A multi-perspective analysis of carrier-
543 grade NAT deployment, in: Proceedings of the 2016 ACM Internet
544 Measurement Conference (IMC), ACM, 2016. doi:10.1145/298744
545 3.2987474.
- 546 [14] J. R. Douceur, The Sybil attack, in: Peer-to-Peer Systems (IPTPS
547 2002), Vol. 2429 of LNCS, Springer, 2002, pp. 251–260. doi:10.100
548 7/3-540-45748-8_24.
- 549 [15] A. Wald, Sequential tests of statistical hypotheses, The Annals of Math-
550 ematical Statistics 16 (2) (1945) 117–186. doi:10.1214/aoms/1177731
551 118.
- 552 [16] E. S. Page, Continuous inspection schemes, Biometrika 41 (1/2) (1954)
553 100–115. doi:10.2307/2333009.
- 554 [17] V. V. Veeravalli, T. Banerjee, Quickest change detection,
555 arXiv:1210.5552 (book chapter) (2012).
- 556 [18] NIST/SEMATECH, CUSUM control charts, section 6.3.2.3, e-handbook
557 of statistical methods, [https://www.itl.nist.gov/div898/handbook](https://www.itl.nist.gov/div898/handbook/pmc/section3/pmc323.htm)
558 [/pmc/section3/pmc323.htm](https://www.itl.nist.gov/div898/handbook/pmc/section3/pmc323.htm), accessed 2026-10-02.
- 559 [19] S. R. Howard, A. Ramdas, J. McAuliffe, J. Sekhon, Time-uniform, non-
560 parametric, nonasymptotic confidence sequences, The Annals of Statis-
561 tics 49 (2) (2021) 1055–1080. doi:10.1214/20-AOS1991.
- 562 [20] S. Wiefeling, L. Lo Iacono, M. Dürmuth, Is this really you? An empirical
563 study on risk-based authentication applied in the wild, in: ICT Systems
564 Security and Privacy Protection (IFIP SEC 2019), Vol. 562 of IFIP Ad-
565 vances in Information and Communication Technology, Springer, 2019,
566 pp. 134–148. doi:10.1007/978-3-030-22312-0_10.

- 567 [21] C. Mulliner, R. Borgaonkar, P. Stewin, J.-P. Seifert, SMS-based one-
568 time passwords: Attacks and defense, in: Detection of Intrusions and
569 Malware, and Vulnerability Assessment (DIMVA 2013), Vol. 7967 of
570 LNCS, Springer, 2013, pp. 150–159. doi:10.1007/978-3-642-39235-
571 -1_9.
- 572 [22] H. Siadati, T. Nguyen, P. Gupta, M. Jakobsson, N. Memon, Mind your
573 SMSes: Mitigating social engineering in second factor authentication,
574 Computers & Security 65 (2017) 14–28. doi:10.1016/j.cose.2016.
575 09.009.
- 576 [23] N. Ahmed, OTP Guard: a layered SMS validation, risk-scoring and
577 rate-limiting pipeline against OTP flood abuse (version 2.9.1), <https://github.com/nahmedpsu/OTP-DDoS>, tag v2.9.1, results produced by
578 2.9.0 (commit 9af3100), whose executable code 2.9.1 keeps; 2.8.0 results
579 (commit 1c277a0) in results/historical_2.8 (2026).
580
- 581 [24] Google LLC, SMS retriever API overview, <https://developers.google.com/identity/sms-retriever/overview>, accessed 2026-10-01.
582
- 583 [25] Web Incubator Community Group, WebOTP API, <https://github.com/WICG/WebOTP>, accessed 2026-10-01.
584
- 585 [26] J. Heinanen, R. Guerin, A single rate three color marker, RFC 2697,
586 Internet Engineering Task Force (1999). doi:10.17487/RFC2697.
- 587 [27] Twilio Inc., Verify API, <https://www.twilio.com/en-us/user-authentication-identity/verify>, accessed 2026-10-03.
588